MITRE ATLAS | AML.CS0031 - Malicious Models on Hugging Face

Entry Information

ID:
AML.CS0031

Type:
Case-Study

Name:
Malicious Models on Hugging Face

URL:
https://atlas.mitre.org/studies/AML.CS0031/

Incident Date:
2025-02-25

Target:
Hugging Face users

Actor:
Unknown

Description

Researchers at ReversingLabs have identified malicious models containing embedded malware hosted on the Hugging Face model repository. The models were found to execute reverse shells when loaded, which grants the threat actor command and control capabilities on the victim's system. Hugging Face uses Picklescan to scan models for malicious code, however these models were not flagged as malicious. The researchers discovered that the model files were seemingly purposefully corrupted in a way that the malicious payload is executed before the model ultimately fails to de-serialize fully. Picklescan relied on being able to fully de-serialize the model.

Since becoming aware of this issue, Hugging Face has removed the models and has made changes to Picklescan to catch this particular attack. However, pickle files are fundamentally unsafe as they allow for arbitrary code execution, and there may be other types of malicious pickles that Picklescan cannot detect.

Attack Procedure:
[AML.T0018.002] Embed Malware: The adversary embedded malware into an AI model stored in a pickle file. The malware was designed to execute when the model is loaded by a user.

ReversingLabs found two instances of this on Hugging Face during their research.
[AML.T0058] Publish Poisoned Models: The adversary uploaded the model to Hugging Face.

In both instances observed by the ReversingLab, the malicious models did not make any attempt to mimic a popular legitimate model.
[AML.T0076] Corrupt AI Model: The adversary evaded detection by [Picklescan](https://github.com/mmaitre314/picklescan), which Hugging Face uses to flag malicious models. This occurred because the model could not be fully deserialized.

In their analysis, the ReversingLabs researchers found that the malicious payload was still executed.

[AML.T0010] AI Supply Chain Compromise: Because the models were successfully uploaded to Hugging Face, a user relying on this model repository would have their supply chain compromised.
[AML.T0011.000] Unsafe AI Artifacts: If a user loaded the malicious model, the adversary's malicious payload is executed.
[AML.T0072] Reverse Shell: The malicious payload was a reverse shell set to connect to a hardcoded IP address.

References

- Malicious ML models discovered on Hugging Face platform — https://www.reversinglabs.com/blog/rl-identifies-malware-ml-model-hosted-on-hugging-face?&web_view=true